

CAPÍTULO 3 · RESUMO DE ESTUDO

Controle de Acessos, Políticas de Segurança e Gerenciamento de Identidades

Os modelos de controle de acesso (DAC → RBAC → ABAC → PBAC), o que compõe uma boa política de segurança da informação e como o IAM une essas duas frentes no ciclo completo de identidades — condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base Nist SP 800-53/63/207, ABNT NBR ISO/IEC 27001, LGPD, CIS Controls, Microsoft Ignite/Security

1. Modelos de controle de acesso

2. Política de segurança

3. Gerenciamento de identidades (IAM)

Termos-chave

Revisão rápida

01

Modelos de controle de acesso

Controle de acesso é o procedimento de aprovar ou recusar pedidos de acesso a informações, serviços e locais físicos (Nist SP 800-53 rev. 5). Os quatro modelos abaixo representam uma evolução, do mais simples ao mais adaptável ao contexto.

DAC**Discretionary Access Control**

O proprietário de cada objeto decide quem acessa, conforme seu próprio

RBAC**Role-Based Access Control**

Permissões atribuídas por função/cargo. O mais comum em médias/grandes

ABAC**Attribute-Based Access Control**

Permissões baseadas em atributos dinâmicos: usuário, recurso, ação e

julgamento. Modelo tradicional e mais simples.

empresas (ex.: Azure Active Directory).

contexto (horário, local). Comum em nuvem.

PBAC

Policy-Based Access Control

Evolução do ABAC: controle centralizado por políticas organizacionais avaliadas em tempo real, alinhado a zero trust.

ZERO TRUST (NIST SP 800-207)

Modelo que **elimina a confiança presumida**: exige verificação contínua de todos os acessos, independente de localização ou tipo de entidade (humana ou não humana). Substitui a defesa centrada na borda/perímetro por decisões de acesso dinâmicas e contextuais, aplicando o **princípio do menor privilégio**.

CERTIFICADOS, DIRETÓRIOS E IDPS

Certificados digitais **X.509** autenticam identidades (ex.: HTTPS/TLS, com cifras como AES-GCM ou ChaCha20-Poly1305 — IETF, 2016) e, no Brasil, o **e-CPF/e-CNPJ** emitidos pela **ICP-Brasil**. Os atributos das contas continuam armazenados em diretórios como **LDAP/Active Directory**, mas a autenticação hoje passa por **provedores de identidade (IdPs)**, que oferecem **Single Sign-On (SSO)** — um único login dá acesso a várias aplicações.

02

Política de segurança e melhores práticas

A política de segurança da informação (PSI) é o documento normativo que define orientações, normas, controles e responsabilidades — o "manual oficial" para funcionários, fornecedores e parceiros. Os modelos de controle de acesso

(DAC/RBAC/ABAC/PBAC) são a camada prática que implementa o que a PSI determina.

Estrutura comum de uma PSI

SEÇÃO	CONTEÚDO
Objetivo	Esclarece a finalidade da política.
Escopo	Especifica ambientes, sistemas e usuários incluídos.
Diretrizes	Explicam os controles e normas a serem seguidos.
Responsabilidades	Descreve os papéis e deveres das partes envolvidas.
Penalidades	Determinam as consequências para violações das normas.

Política de senhas — o que mudou com o Nist SP 800-63B

ABORDAGEM TRADICIONAL

- Foco na complexidade forçada (maiúsculas, números, símbolos)
- Troca periódica obrigatória, em intervalos fixos
- Uso de perguntas de segurança
- Truncar credenciais ou aceitar só certos caracteres

RECOMENDAÇÃO ATUAL (SP 800-63B)

- Prioriza **comprimento**: mínimo de 15 caracteres
- Troca só é exigida em caso de **comprometimento** da credencial
- Elimina perguntas de segurança (vulneráveis a engenharia social)
- **Blocklist** de senhas fracas/vazadas; permite copiar, colar e visualizar a senha
- Transmissão/armazenamento com hash + **salt** único e fator de custo ajustável

Além da política de senhas, uma PSI robusta cobre: **backups** (disponibilidade e recuperação de dados), **resposta a incidentes** (ações em caso de falhas) e **gestão de atualizações** / patch management (correção rápida de vulnerabilidades).

Boas práticas: revisão da política a cada **seis meses**, treinamentos contínuos de conscientização, e conformidade com legislações (LGPD) e normas internacionais (ABNT NBR ISO/IEC 27001).

03

Gerenciamento de identidades e acessos (IAM)

IAM (identity and access management) é a união prática entre os modelos de controle de acesso e as diretrizes da política de segurança: um conjunto de processos e tecnologias que garante que identidades digitais sejam autenticadas, autorizadas e monitoradas de forma alinhada às normas. Vai além de senha e login — abrange todo o ciclo de vida da identidade, de colaboradores a parceiros, dispositivos e APIs.

01 • autenticação

Quem é você

Verifica a identidade via login/senha, fortalecida por autenticação multifator (MFA). Ex.: Microsoft Entra ID.

02 • autorização

O que você pode acessar

Define nível de acesso com base em RBAC/ABAC, aplicando o princípio do menor privilégio.

03 • provisionamento

Criar, alterar, revogar

Ciclo controlado de contas, minimizando contas inativas e privilégios excessivos. Ferramentas de IGA (ex.: SailPoint).

04 • monitoramento

Auditoria contínua

Logs detalhados, análise de comportamento e alertas para identificar atividades suspeitas e cumprir conformidade.

SSO — SINGLE SIGN-ON

Permite que o usuário faça uma única autenticação para acessar vários sistemas, reduzindo a fadiga de senhas e a quantidade de credenciais em uso — recurso oferecido pelos IdPs modernos.

Anexo — principais ferramentas de IAM

FERRAMENTA	DESCRIÇÃO
Okta	Solução em nuvem para gestão de identidade e acesso, com SSO, MFA, diretórios universais e integração SaaS.
Microsoft Entra ID	IAM da Microsoft (antigo Azure AD): autenticação, acesso condicional, gestão em nuvem e híbrido.
IBM Security Verify	Autenticação multifator, federação de identidades e acesso único, com suporte a SAML/OAuth.
Oracle Identity Management	Governança de identidades com provisionamento automático e controles de acesso adaptativos.
AWS IAM	Gerencia permissões granulares para recursos AWS, com acesso cross-account.



Termos-chave

Vocabulário que costuma aparecer em questões de múltipla escolha.

Menor privilégio Cada identidade recebe apenas o acesso estritamente necessário para sua função.	ZTA Zero Trust Architecture — abordagem que protege identidades humanas e não humanas sem confiança implícita.
X.509 Padrão de certificado digital usado para autenticação e controle de acesso (ex.: HTTPS).	IdP Identity Provider — serviço que autentica identidades e viabiliza o SSO.
LDAP / Active Directory Diretórios que centralizam informações de identidade e credenciais.	Salt Valor aleatório único adicionado à senha antes do hashing, dificultando ataques de força bruta.
Blocklist	IGA

Lista de senhas proibidas por serem fracas, previsíveis ou já vazadas.

Identity Governance and Administration — automação da governança e administração de identidades.

Patch management

Gestão de atualizações de segurança para corrigir vulnerabilidades identificadas.

PSI

Política de Segurança da Informação — documento normativo com regras, controles e responsabilidades.



Revisão rápida antes da prova

Confira se você consegue responder a cada ponto sem consultar o texto.

- ☐ Explicar a diferença entre DAC (decisão do proprietário) e RBAC (baseado em função).
- ☐ Explicar por que o PBAC é considerado uma melhoria do ABAC.
- ☐ Descrever o princípio central do zero trust e como ele substitui a defesa por perímetro.
- ☐ Diferenciar a relação entre política de segurança (regras) e modelos de controle de acesso (implementação prática).
- ☐ Listar as mudanças do Nist SP 800-63B em relação a senhas (comprimento x complexidade, troca só em comprometimento, fim das perguntas de segurança).
- ☐ Explicar o que é salt e por que ele fortalece o armazenamento de senhas.
- ☐ Listar as 5 seções típicas de uma PSI (objetivo, escopo, diretrizes, responsabilidades, penalidades).
- ☐ Descrever as 4 etapas do ciclo de IAM: autenticação → autorização → provisionamento → monitoramento.

☐ Explicar o que é SSO e qual problema ele resolve.

☐ Citar pelo menos duas ferramentas de IAM e sua característica principal.



Referências do capítulo

ABNT. NBR ISO/IEC 27001:2024. Sistemas de gestão da Segurança da Informação — Requisitos.

BRASIL. Lei nº 13.709/2018 (LGPD); Instituto Nacional de Tecnologia da Informação. ICP-Brasil, 2025.

CIS. CIS Critical Security Controls v8.1, 2025.

IETF. ChaCha20-Poly1305 cipher suites for TLS. RFC 7905, 2016.

Microsoft. What is Azure RBAC?; What is access control?; What is Microsoft Entra? Microsoft Ignite/Security, 2024–2025.

Nist. SP 800-53 rev. 5 (2020a); SP 800-207 Zero Trust Architecture (2020b); SP 800-63B/C Digital Identity Guidelines (2017; 2025b–d); Information Security Handbook SP 800-100 (2006); Guide to ABAC SP 800-162 (2014).

SailPoint. What is identity and access management (IAM)? 2025.

Security Executive Council; Sans Institute; ICIMS Inc.; Purplesec. Templates de políticas de segurança da informação.

Resumo gerado a partir do capítulo "Controle de acessos, políticas de segurança e gerenciamento de identidades" (SEG_AUD_SIS_03_ACE_2025) para revisão de prova.